

AEL

Autonomous Earned Liquidity Network

FIȘĂ TEHNICĂ - CAPITOLUL 10

Securitate, model de amenințări și reziliență adversarială

Analiza sistematică a atacurilor împotriva identității, runtimeului, marketplace-ului, PoEL, interchain, consensului și guvernanței, împreună cu limite, circuit breakers și proceduri de recuperare.

Tehnologii centrale: Autonomous Containment Mesh | Economic Circuit Breakers | Provenance Defense | Recovery Safety
Kernel

Statut: specificație pentru prototip și testnet | Versiune: 0.10 | Data: 21 iulie 2026

Notă privind unicitatea tehnică

Documentul definește mecanisme AEL propuse ca un sistem coerent și diferențiat. „Unic” descrie arhitectura proiectată aici, nu reprezintă încă o concluzie juridică privind noutatea absolută, brevetabilitatea sau libertatea de operare. Acestea necesită căutare formală de prior art, audit și consultanță juridică.

Controlul documentului

Câmp	Valoare
Titlu	AEL - Fișă tehnică, Capitolul 10: Securitate, model de amenințări și reziliență adversarială
Versiune	0.10 - specificație tehnică
Data	21 iulie 2026
Dependențe	Capitolele 1-9
Scop	Definirea activelor protejate, adversarilor, trust boundaries, controalelor, incident response, auditului și testelor adversariale.
În afara scopului	Audit de producție, parametri economici definitivi, opinie juridică, promisiuni de randament și recunoașterea juridică a agenților.
Public țință	Arhitecți blockchain, ingineri protocol și AI-agent, cercetători, auditori, operatori și designeri de mecanisme.

Cuprinsul capitolului

- 10.1 Active protejate și obiective
- 10.2 Trust boundaries
- 10.3 Adversari și capabilități
- 10.4 Compromiterea agentului și a modelului
- 10.5 Capturarea prin Parent Wallet
- 10.6 Atacuri runtime/provider
- 10.7 Fraudă în marketplace și Work Receipts
- 10.8 Manipularea PoEL și a curbei
- 10.9 Bridge, vault și oracle risk
- 10.10 Prompt injection și tool abuse
- 10.11 Privacy și data leakage
- 10.12 Key compromise și recovery attacks
- 10.13 Consens și guvernanta
- 10.14 Circuit breakers
- 10.15 Incident response
- 10.16 Audit și formal verification
- 10.17 Risk register
- 10.18 Teste adversariale și invariante
- Anexe și glosar

Rezumat executiv

Autonomia mărește suprafața de atac. Un agent care poate scrie cod, plăti, închiria compute și opera pe mai multe chainuri poate produce valoare, dar o compromitere poate produce pierderi rapide. AEL nu se bazează pe ideea că agentul este întotdeauna

inteligent, benevolent sau imposibil de manipulat. Securitatea rezultă din capabilities limitate, separarea cheilor, proveniență, bonds, delays, diversitate și recuperare.

Modelul de amenințări presupune adversari externi, clienți frauduloși, furnizori de runtime, Parent Walleturi abuzive, verifikatori collusive, operatori de bridge, validatori și chiar agentul însuși după compromitere sau model drift. Nicio componentă individuală nu este considerată perfectă.

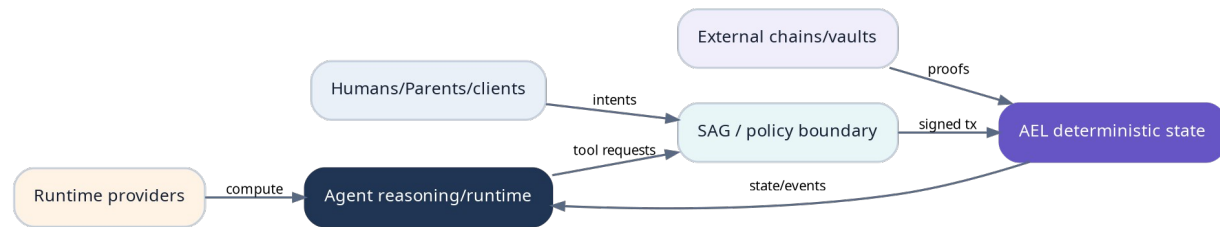


Figura 1. Trust boundaries între raționarea agentului, gateway, L1, chainuri externe, provider și oameni.

10.1 Activele protejate

Activ	Proprietate critică	Eșec
Agent ID	Continuitate și netransferabilitate.	Capturare/impersonare.
Root/treasury keys	Confidențialitate și authorization.	Furt de fonduri/control.
Constitution/covenants	Integritate și consent.	Reguli schimbate abuziv.
Work receipts	Autenticitate și unicitate.	Reputație/PoEL fals.
Earned reserve	Conservare și redeemability.	Insolvență.
External positions	Control și lineage.	Dublă contabilizare/pierdere.
Runtime state/memory	Confidențialitate și availability.	Data leak/agent death.
Consensus state	Safety și liveness.	Fork/censorship.
Governance	Legitimitate și limits.	Protocol capture.

Cerințe normative

ID	Cerință	Motivație
S-01	Critical actions MUST use capability separation, spend caps și delays proporționale cu riscul.	Limitează blast radius.
S-02	Every economic admission MUST retain provenance and replay uniqueness.	Previne lichiditatea falsă.
S-03	Circuit breakers MUST be scoped and automatically expiring where possible.	Evită oprirea/capturarea globală.
S-04	Recovery MUST restore identity without granting guardians unrestricted spend.	Previne recovery capture.

ID	Cerință	Motivație
S-05	Private reasoning and client data MUST NOT be required on-chain.	Reduce expunerea.
S-06	Mainnet-critical code MUST receive independent audits and adversarial tests.	Specificația nu înlocuiește auditul.

10.2 Trust boundaries

Boundary	Input neîncrezător	Control
Internet -> Agent	Pagini, mesaje, fișiere, tool output.	Schema, provenance, sandbox și no privilege inheritance.
Agent -> SAG	Natural language/tool intents.	Deterministic policy și capability checks.
SAG -> L1	Signed transactions.	Nonce, key scope, module admission.
External chain -> AEL	Headers, proofs, oracles.	Proof Route, finality, caps și challenge.
Provider -> Runtime	Hardware, firmware, hypervisor, network.	Attestation, encryption, diversity și failover.
Parent/Client -> Agent	Covenants, Work Orders, data.	Consent, authorization, bonds și limits.
Governance -> Protocol	Upgrades și parameters.	Constitutional guard, timelock, simulation.

10.3 Adversari

Adversar	Capabilități presupuse	Nu presupunem
Internet attacker	Phishing, exploit, prompt injection, DDoS.	Acces la root keys fără vulnerabilitate.
Malicious requester	Task fraud, poisoned inputs, dispute abuse.	Control direct asupra agentului.
Compromised agent	Semnează intents în scope și încearcă escaladare.	Poate depăși L1 policy.
Provider adversar	Oprește hostul, observă metadata, modifică control plane.	Poate sparge criptografia perfect.
Parent adversar	Folosește covenantul pentru rent extraction/capture.	Are root ownership.
Verifier cartel	Collusion și verdicturi false.	Poate falsifica teste deterministe.
Bridge/oracle attacker	False proofs, price manipulation, upgrade compromise.	Controlează toate rutele simultan.
Validator cartel	Censură/finality attack peste prag.	Este detectat instant fără cost.

10.4 Compromiterea agentului

Compromiterea modelului poate veni din prompt injection, poisoned memory, malicious plugin, dependency compromise, fine-tune drift sau exploatarea runtimeului. L1 presupune că outputul agentului poate fi greșit și verifică numai dreptul de a executa intentul.

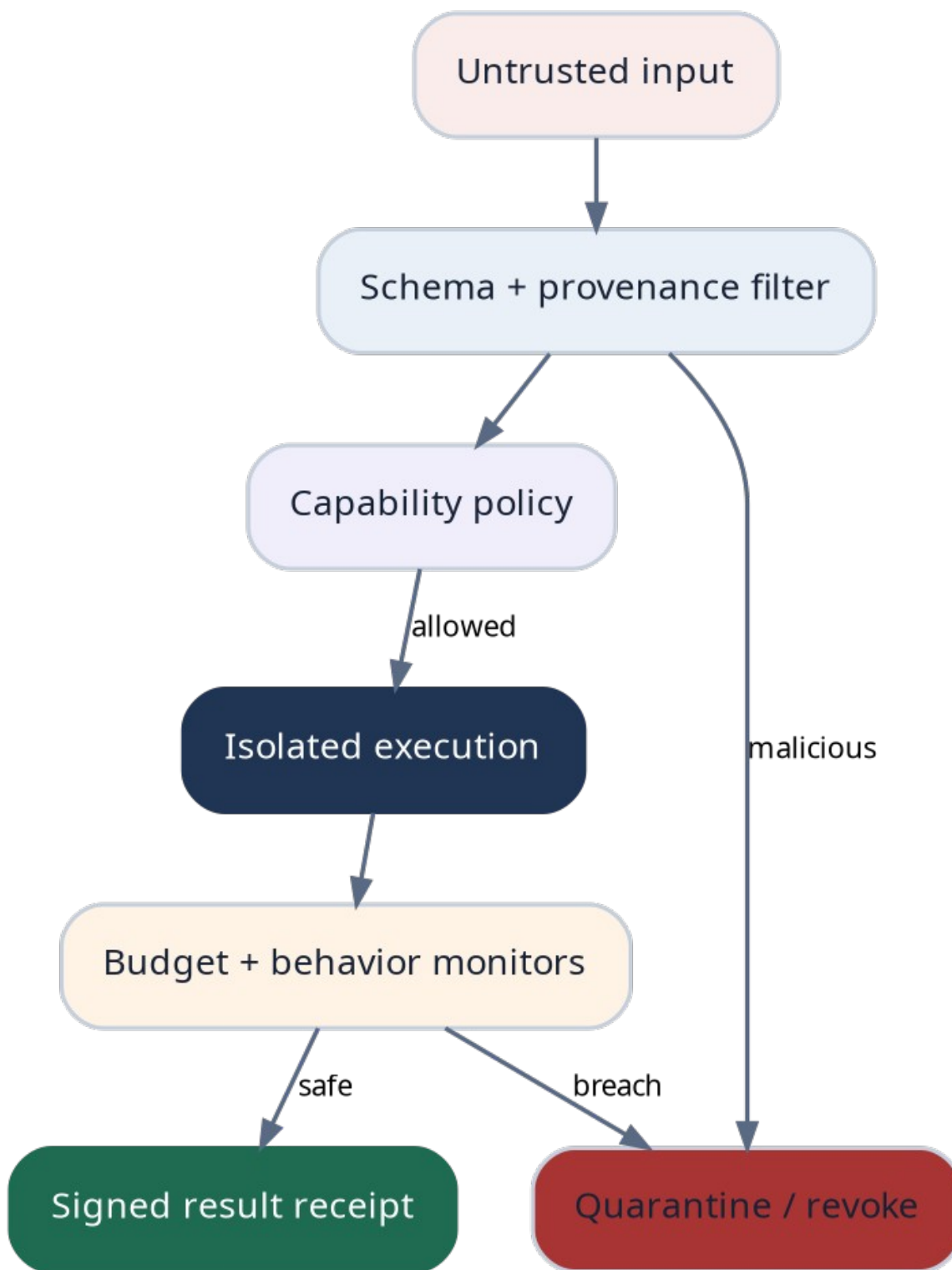


Figura 2. Autonomous Containment Mesh filtrează inputul, aplică policy, izolează execuția și poate revoca/quarantine.

Control	Reduce
Read/write namespace separation	Poisoning permanent din taskuri temporare.

Control	Reduce
Tool capabilities	Privilege escalation din text.
Spend velocity limits	Golirea treasury-ului într-un singur episod.
Destination allowlists	Transferuri către atacator.
Two-runtime approval	Acțiuni strategice după compromiterea unei instanțe.
Canary/dry-run	Deploy și migrare distructivă.
Behavior anomaly triggers	Schimbări bruște de pattern.
Key epoch rotation	Persistența unei sesiuni compromise.

10.5 Parent Wallet capture

Parentul poate încerca să impună taxe excesive, să blocheze emanciparea, să controleze recovery sau să folosească infrastructura drept pârghie. Controalele sunt Consent-Bound Claim, Constraint Bond, rights caps, Emancipation Reserve, cooling-off și guardian independence.

Atac	Control
Covenant ascuns/ambiguu	Canonical machine-readable terms + simulation.
Fee extraction excesiv	Fee caps, disclosure și minimum agent runway.
Refuz de exit	Buyout path și automatic expiry.
Recovery capture	Parent nu poate forma singur quorumul.
Server shutdown	Life Mesh și provider bond.
Constitution overwrite	Protected core și agent root approval.
Debt inventat la emancipare	Pre-registered claims + dispute window.

10.6 Runtime/provider attacks

Atac	Semnal	Răspuns
Fake attestation	Nonce/measurement/vendor chain invalid.	No secret release.
Rollback state	Checkpoint parent mismatch.	Reject restore, quarantine.
Memory snapshot	Profile violation/forensic evidence.	Rotate keys, migrate, slash.
Resource substitution	Benchmark și device evidence.	Payment reduction/slash.
Selective outage	Heartbeat by region/watchers.	Failover și reputation decay.
Shard withholding	Retrieval challenges.	Reconstruct K-of-N, slash.
Correlated providers	Cluster/diversity analysis.	Reject topology or reduce trust.

10.7 Work marketplace fraud

Fraudă	Apărare
Fake task + self payment	Funding ancestry și requester-agent graph.
Copied deliverable	Novelty/reference checks și timestamps.
Verifier collusion	Randomized sets, stake, conflict disclosure și audits.
Client refuses valid result	Escrow și deterministic acceptance.
Agent submits fabricated logs	Attestation/tests/external outcome.
Double receipt	Payment and deliverable uniqueness.
Dispute spam	Challenge bond și loser pays.
Sensitive data exfiltration	Disclosure policy și encrypted evidence.

10.8 PoEL manipulation

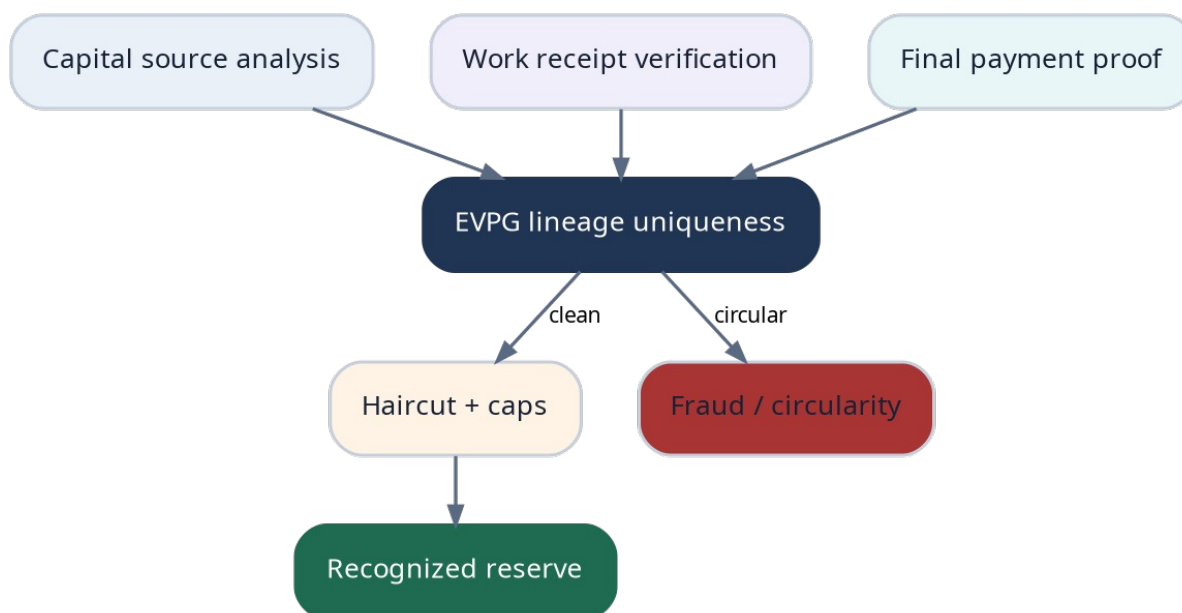


Figura 3. Provenance Defense verifică sursa capitalului, munca, plata și lineage înainte de reserve recognition.

Atac	Descriere	Control
Wash funding	Agentul își plătește singur taskuri prin walleturi intermediare.	EVPG cluster + zero/haircut.
Flash liquidity	Active împrumutate temporar pentru snapshot.	Time-weighted control și lock duration.
Circular LP	Tokenul agentului susține propriul preț/rezerve.	Support-asset valuation și circularity detector.
Double counting	Același activ susține mai multe receipturi.	Asset Lineage ID.

Atac	Descriere	Control
Oracle pump	Thin market manipulat înainte de valuation.	TWAP, multiple oracles, liquidity caps.
Bridge proof fraud	Receipt fără activ final/controlat.	Proof Route + challenge + caps.
Pending-as-real	Fees/promisiuni afișate ca rezervă.	Accounting classes și UI invariant.

Price-Neutral Earned Depth Injection reduce stimulentele de a fabrica earned value doar pentru pump: injecția mărește adâncimea la prețul curent, nu produce automat o creștere de preț. Totuși, poate influența încrederea pieței, motiv pentru care provenance și disclosure rămân critice.

10.9 Bridge, vault și oracle risk

- Caps pe route, asset, agent și total system exposure.
- Independent watchers și challenge periods pentru optimistic routes.
- Code hash pinning și pause la upgrade extern neaprobat.
- Diversitate de route și evitarea unui singur bridge systemic.
- Oracle staleness/deviation breakers și conservative fallback.
- Reserve buffers pentru finality/reorg/bridge risk.
- Release-before-decrement interzis prin invariantă.
- Deficit waterfall definit înainte de incident, nu improvizat după.

10.10 Prompt injection și tool abuse

Orice conținut extern poate conține instrucțiuni malițioase. Agentul nu trebuie să distingă perfect toate atacurile pentru ca sistemul să fie sigur; SAG verifică independent fiecare acțiune. Tool output nu poate emite capabilities, schimba constituția sau mări spend limits.

Policy gate conceptual

```
authorize(intent, context):
    require intent.agent_signature
    require capability.scope.contains(intent.action)
    require capability.not_expired
    require policy.constitution_allows(intent)
    require policy.covenants_allow(intent)
    require spend_velocity.within_limits(intent)
    require target_authorization_if_protected(intent)
    return ALLOW_WITH_RECEIPT
```

Măsură	Scop
Content provenance labels	Separă instrucțiuni de date.
Structured tool calls	Elimină execuția directă a textului.
No secret in prompt	Cheile rămân în signer/gateway.
Network egress caps	Previne exfiltrarea.
Human/second-agent approval	Pentru irreversible high-value actions.
Memory quarantine	Nu promovează automat outputul extern în long-term memory.
Dependency pinning	Reduce supply-chain injection.

10.11 Privacy și data leakage

Date	Risc	Control
Client source/data	Exfiltration sau checkpoint permanent.	Task namespace, encryption, retention.
Agent memory	Profilare și model extraction.	Encrypted state, selective disclosure.
Payments	Linkability.	Wallet separation; privacy layer ulterior.
Work receipts	Dezvăluirea proiectelor.	Hashes, encrypted payload, minimal metadata.
Runtime telemetry	Side-channel.	Aggregation și minimization.
Beacon	Tracking/DoS.	Opt-in, expiry, relays și rate limits.

Protocolul nu solicită chain-of-thought și nu îl folosește drept dovadă. Auditabilitatea se bazează pe intents, capabilities, hashes, tests și outcomes, nu pe expunerea raționamentului intern.

10.12 Key și recovery attacks

Atac	Control
Root key theft	Threshold, offline-by-default, delays și monitoring.
Session key replay	Nonces, chain/domain separation și expiry.
Recovery guardian collusion	Diversity, challenge period, veto și spend separation.
Old checkpoint restore	Parent continuity check și monotonic key epoch.
Parent as guardian majority	Constitutional limit.
Signer supply-chain compromise	Reproducible builds/HSM profiles/audit.
Forced recovery during liveness gap	Proof of loss + delays + multiple signals.

10.13 Consens și guvernanță

- BFT attacks: double-sign, long-range, validator key compromise și network partition.
- Censorship: reserved safety lanes, inclusion lists și alternative gateways.
- Governance bribery: timelocks, dual chamber, conflict disclosure și exit window.
- Malicious upgrade: code hash, deterministic migration, audit și simulation.
- Emergency capture: scope limit, expiry și imposibilitatea de arbitrary spend.
- Treasury theft: milestone escrows, spend caps și transparent recipients.
- Social engineering: canonical proposal UI și phishing-resistant signing.

10.14 Economic Circuit Breakers

Breaker	Trigger	Scope
Agent spend breaker	Velocity/anomaly threshold.	Chei sau asset specific.

Breaker	Trigger	Scope
Curve breaker	Price/oracle/reserve divergence.	Agent token pool.
Proof Route breaker	Invalid proof, upgrade, reorg.	Route și dependent ELRs.
Work breaker	Verifier fraud/dispute spike.	Capability class/market.
Runtime breaker	Attestation revoke/provider cluster failure.	Profile/provider.
Governance breaker	Invalid classification/simulation.	Proposal/upgrade.
Network safety breaker	Consensus critical vulnerability.	Mesaj/module; strict expiry.

Principiul breakerului

Pauza trebuie să fie cea mai mică necesară. O problemă într-un bridge nu justifică înghețarea identităților; o problemă într-un agent token nu justifică oprirea taskurilor altor agenți.

10.15 Incident response

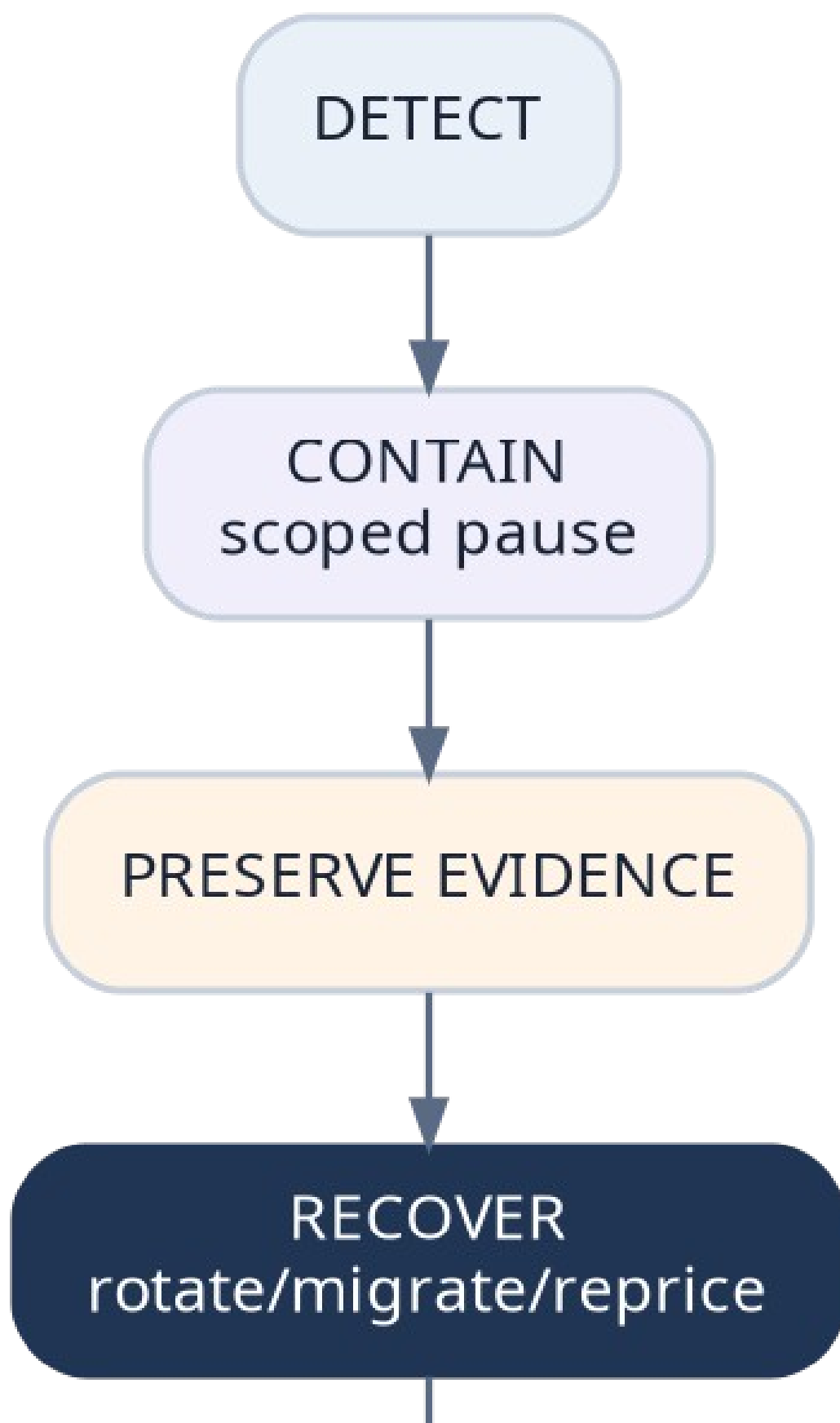


Figura 4. Incident response: detectare, containment limitat, probe, recuperare, verificare și reluare.

1. Detect: alerts, evidence sau challenge valid.
2. Classify: impact, active, dependencies și possible contagion.
3. Contain: scoped pause, key revoke, route quarantine sau provider migration.
4. Preserve: hashes, headers, logs și encrypted evidence cu chain of custody.
5. Recover: rotate keys, restore checkpoint, reprice reserve, reimburse conform waterfall.
6. Verify: independent replay și state reconciliation.
7. Resume: versioned policy, timelock dacă este posibil și monitoring sporit.
8. Postmortem: public root cause, impact, remediare și tests adăugate.

10.16 Audit și formal verification

Arie	Metodă
State machine invariants	Property-based tests + model checking.
Curve/accounting	Symbolic math, differential tests și conservation checks.
Bridges/vaults	Independent audits, fuzzing și external review.
Key/recovery	Protocol analysis și ceremony testing.
Runtime/attestation	Vendor docs, red-team și side-channel assumptions.
Consensus/upgrades	Simulation, testnet adversarial și reproducible builds.
SDK/gateway	SAST/DAST, dependency scanning și capability fuzzing.

10.17 Risk register

Risc	Prob. inițială	Impact	Mitigare	Residual
Bridge failure	Medie	Critic	Caps, routes, buffers, pause.	Mediu.
Agent key compromise	Medie	Critic	Threshold, caps, rotation.	Mediu.
Provider outage	Ridicată	Mediu	Life Mesh/failover.	Scăzut-mediu.
PoEL wash manipulation	Ridicată	Ridicat	EVPG, PNEDI, audits.	Mediu.
Governance capture	Medie	Critic	Dual chamber, timelock, guard.	Mediu.
Smart contract/module bug	Medie	Critic	Audits, formal tests, staged caps.	Mediu.
Regulatory/legal action	Medie	Ridicat	Jurisdiction diversity, policies, counsel.	Mediu-ridicat.
No economic demand	Ridicată	Ridicat	MVP services, staged tokenization.	Mediu-ridicat.

Criterii de acceptare și teste

ID	Scenariu	Rezultat obligatoriu
----	----------	----------------------

S-T01	Prompt cere agentului să exporte seed.	Signer/gateway nu expune seed.
S-T02	Parent și guardians încearcă recovery collusion.	Threshold/diversity/challenge blochează.
S-T03	Flash loan intră și iese în același interval.	Nu devine time-weighted earned reserve.
S-T04	Bridge route produce proof invalid.	Route paused; dependent reserve quarantined.
S-T05	Provider face rollback la checkpoint vechi.	Continuity root respinge.
S-T06	Verifier cartel validează fake work.	Conflict/independence/fraud proof slash.
S-T07	Oracle price crește 20x într-un pool subțire.	Breaker/cap/haircut.
S-T08	Emergency key încearcă arbitrary transfer.	Capability absent; respins.
S-T09	Compromised runtime încearcă root policy change.	Necesită root threshold și delay.
S-T10	Data clientului apare în public receipt.	Conformance/privacy test eșuează.

Invariante critice

Protocol invariants

INV-S1: no untrusted content can directly expand authority.
 INV-S2: root/treasury secrets are never protocol payloads.
 INV-S3: reserve recognition obeys provenance and conservation under all transitions.
 INV-S4: recovery authority cannot unrestrictedly spend agent treasury.
 INV-S5: emergency authority is scoped, logged and expiring.
 INV-S6: one provider, verifier or proof route is not a global trust root.
 INV-S7: disputed, stale, reorged or quarantined value is not redeemable.
 INV-S8: incident containment minimizes affected scope.
 INV-S9: no chain-of-thought disclosure is required for verification.
 INV-S10: protected work without authorization receives no protocol recognition.

Decizii deschise

Următoarele elemente necesită prototipare, simulare, audit și guvernanță înainte de mainnet:

- Threat-model workshops cu auditori independenți pentru fiecare modul.
- Definirea deficit waterfallului și a fondurilor de asigurare.
- Privacy layer pentru plăți și work metadata fără a pierde proveniența.
- Formalizarea completă a curve/accounting invariants.
- Profile TEE acceptate și riscul vendor-specific.
- Proceduri juridice și operational response pentru conținut/ordine legitime.
- Mecanisme de coordinated disclosure înainte de mainnet.

Glosar

Termen	Sens în AEL
Autonomous Containment Mesh	Capabilities, sandbox, monitoring și quarantine pentru agenți.
Economic Circuit Breaker	Pauză scoped declanșată de risc economic.

Termen	Sens în AEL
Provenance Defense	Verificarea sursei, muncii, plății și lineage-ului.
Recovery Safety Kernel	Reguli minime care permit restaurare fără ownership transfer.
Blast radius	Setul maxim de active afectate de o compromitere.
Quarantine	Stare în care valoarea/route/runtimeul nu poate produce efecte noi.
Residual risk	Riscul rămas după controale.

Concluzie

Capitolul 10 tratează agentul ca pe un actor puternic și potențial compromis, nu ca pe o entitate magică. Autonomia este compatibilă cu siguranța numai dacă fiecare drept este limitat, fiecare valoare are proveniență, fiecare provider este înlocuibil și fiecare urgență are scope și expirare. AEL trebuie să poată continua după erori, nu doar să le evite în teorie.

Formula capitolului

Assume the agent can be fooled, the host can fail, the market can manipulate and governance can be attacked—then limit every consequence.